

Professional issues: Privacy

Privacy is one of the most prevalent professional issues in modern computing. At its core, it concerns the right of individuals to control information about themselves - who collects it, how it is used, and with whom it is shared. For software engineers, it is crucial to recognise that their work carries social and ethical consequences. Nowhere is this more evident than in the domain of data privacy. Applications that collect any form of personal data, even with good intent, carry inherent risks including; data breaches, misuse of behavioural data, and betrayal of user trust.

The consequences of poor privacy practice in software systems can be severe and have lasting impact. One of the most significant examples is the Facebook Cambridge Analytica scandal (2018), in which the personal data of approximately 87 million Facebook users was harvested without explicit consent via a third party quiz application. This data, including personal preferences, social connections, and behavioural patterns, was subsequently used to build psychological profiles and deliver targeted political advertising during major democratic elections. Consequently, Facebook faced billions of dollars in regulatory fines, public trust in social media platforms collapsed, and new data protection legislation was accelerated globally.

A subtler but equally revealing case is that of recommendation systems. Recommendation systems are widely used across a variety of online commercial services, including shopping platforms, streaming services, and news outlets. They are designed to suggest products, services, and content to users based on predictions derived from individual user history and behaviour on a given platform.

However, the prevalence of recommendation systems has brought a number of ethical concerns into sharp focus. A notable case is the 2009 lawsuit against Netflix, which was issued for allegedly violating users' privacy by releasing "anonymous" data that could be traced back to individuals. Milano et al. (2020) highlighted that privacy risks in recommender systems occur at multiple stages: when data is collected or shared without explicit consent, when stored datasets are leaked or subject to de-anonymisation attempts, when the system draws inferences from data that users may not be aware of, and through collaborative filtering itself, where a model of one user can be constructed from data gathered about others.

Both cases highlight that the data required to create an algorithm which suggests useful recommendations is precisely the kind of data that, if mishandled, can cause real harm.

Developing a book recommendation system presented a particularly nuanced ethical landscape. Reading habits are deeply personal. The genres a person reads, the books they rate highly, and the topics they seek out can reveal sensitive aspects of their identity, beliefs, mental health, or personal circumstances. For example, a user who reads extensively about addiction recovery, or explores certain political paradigms or religious ideas is, although subtly, disclosing private information simply by engaging with the system.

This raises several important ethical debates. First, there is the question of personal autonomy and influence. Milano et al. (2020) describes recommendation systems as functioning like

“sticky traps” that exploit rather than negate user autonomy, nudging users toward particular content in ways that may serve commercial interests over user welfare. Recommendation algorithms that learn a user’s genre preferences and consistently surface content within that genre risks creating a ‘filter bubble,’ subtly shaping the user’s intellectual direction without their awareness.

Secondly, there is the risk of data commodification. Reading history and genre preferences, if sold or shared with third parties, could be exploited for targeted advertising - for example, a user whose reading history suggests an interest in horror could be targeted by gaming companies or streaming services without ever consenting to that use. This represents a clear violation of the principle of data minimisation emphasised in the UK’s General Data Protection Regulation (UK GDPR), which requires that personal data be collected only for specified, explicit and legitimate purposes.

Third, there is the issue of user profiling and bias. Recommender systems make predictions based on patterns in existing data, but if the recommender learns from biased data, it can unintentionally repeat and strengthen existing inequalities instead of reducing them. This can be explained through a hypothetical job recommendation system. Past data shows mostly men explored engineering jobs. Therefore, the system learns: “Men prefer engineering jobs”, and it starts showing those jobs mostly to men. As a result, women see fewer engineering opportunities and an imbalance is created or worsened. In the context of a book recommendation system, this could mean users from underrepresented groups receive poorer or stereotyped recommendations, subtly reinforcing rather than challenging cultural inequalities.

Awareness of these concerns directly influenced how my project was designed and built. The application requires users to create an account, and in doing so, personal data including usernames (display names), email addresses, reading history, book ratings, and genre preferences are stored. This data is central to the recommendation engine’s functionality. Given its sensitivity, a number of technical and design decisions were made to handle it responsibly.

Several measures were implemented in my project to protect user privacy. When users create an account, passwords are hashed to ensure they are never stored in plaintext. This means that even in the event of a data breach, raw credentials are not exposed. Users are also prompted to create strong passwords with a minimum of eight characters, one capital letter and one special character to mitigate against brute force attacks. Furthermore, authentication and session management are handled using Spring Boot Security 6 alongside JWT tokens. This ensures that user sessions are stateless, cryptographically signed, and that API endpoints are protected from unauthorised access. A user can only access their own data, not that of other users.

Additionally, all database queries use parameterised statements (using the ‘?’ placeholder with authenticated principal binding) rather than raw string concatenation. This prevents SQL injection attacks, a common approach through which attackers extract or manipulate user data. The application was also designed to collect only what is necessary for its core function. No

third-party tracking, advertising SDKs, or analytics tools were integrated, meaning user reading data remains within the application and is not shared or sold.

In a softer sense, the user interface also contributes to privacy as a result of the clear navigation, logical account management flows and visible login states to help users feel in control of their data and engagement with the application.

Whilst the technical measures above provide a solid privacy foundation, the project could go further in several areas. A formal privacy notice or data policy clearly communicating to users what data is collected, how it is used, and how long it is retained was not implemented, but would be critical before any public deployment. Under UK GDPR, users have the right to access, correct, and delete their personal data. Building a terms and conditions page explaining how user data is used would be a necessary next step - users must be able to accept or deny.

Also, the recommendation engine itself lacks transparency. Providing users with a simple explanation of why a book has been recommended - for example, "because you rated fantasy novels highly" - would give users meaningful insight into how their data is being used, addressing both the filter bubble concern and the principle of transparency. This is an area for future development.

To conclude, privacy is not a feature to be considered post-development; it is a professional responsibility that must be built into the software engineering cycle. This project aimed to act in accordance with that responsibility through its technical choices, and the areas where further work would bring it into better compliance with both legal requirements and ethical standards expected of computing professionals are recognised.

Word count: 1263

References

Singel, Ryan. "Netflix spilled your Brokeback Mountain secret, lawsuit claims." *Threat Level (blog)*, *Wired* 1 (2009).

"Data Protection." *GOV.UK*, UK Government, <https://www.gov.uk/data-protection>. Accessed 8 Apr. 2026.

Cadwalladr, C. and Graham-Harrison, E. (2018) 'Revealed: 50 million Facebook profiles harvested for Cambridge Analytica in major data breach'. *The Guardian*, 17 March. Accessed 8 Apr 2026

Milano, S., Taddeo, M. and Floridi, L. (2020) 'Recommender systems and their ethical challenges'. *AI & Society*, 35, pp. 957–967.